NOTE 01 - WHAT IS MITRE ATT&CK?

Definition

MITRE ATT&CK stands for Adversarial Tactics, Techniques and Common Knowledge.

It is a free, publicly available knowledge base that documents how real-world attackers behave once they are inside or attacking a network. Instead of listing malware names or tool names, ATT&CK describes the actions an adversary takes - the behaviour itself - and puts every action into a structured, searchable matrix.

It was created by MITRE, a not-for-profit research organisation, and it is built from real-world observations of intrusions, not from theory or guesswork. The first version grew out of MITRE research into advanced persistent threats and was released publicly in 2015; it has been expanded and re-published several times a year ever since.

A simple way to remember it:

> ATT&CK answers the question "What does an attacker actually do after they get in?" - and it answers it in a consistent, shared vocabulary that every defender understands.

Why MITRE ATT&CK matters for SOC analysts and threat detection

Reason	What it means in practice
Common language	Analysts, hunters, detection engineers, threat intel and management all describe behaviour with the same labels - Alert "T1059.001" means the same thing in every SOC.
Moves the focus to behaviour	Detection stops depending on an ever-changing file hash or malware name and starts looking at what the attacker does, so brand-new malware using an old technique is still caught.
Threat-informed defence	The SOC prioritises defenders' effort on the techniques actually used against its industry, instead of trying to detect everything equally.
Detection engineering	Each detection rule can be tagged to the technique it covers, so coverage can be measured as a heat map and obvious gaps become visible.
Faster triage and escalation	An analyst can name the tactic and technique in the ticket in one line, which tells the L2/L3 analyst and the incident responder exactly why the alert matters.
Support for threat hunting	Hunt hypotheses are written directly from the matrix: "we have no visibility on T1053 scheduled tasks - let us go and look".
Better reporting	Executives and auditors understand an incident framed as "the attacker reached the Credential Access and Lateral Movement tactics" far better than a list of raw alerts.
Purple teaming	Red team actions and blue team detections are both recorded in ATT&CK terms, so gaps found in an exercise can be closed and re-tested.
Prioritisation of alerts	Techniques that indicate hands-on-keyboard activity and lateral movement are treated as high severity; a single failed logon is not.

What ATT&CK is made of

Component	What it is	Example
Tactic	The attacker's goal at a stage of the intrusion	Credential Access
Technique	How the goal is achieved	T1003 OS Credential Dumping
Sub-technique	A more specific way of doing the same technique	T1003.001 LSASS Memory
Procedure	The exact implementation used by a real actor or tool	Mimikatz `sekurlsa::logonpasswords`
Group	A tracked threat actor	Named APT or criminal group
Software	Malware or tooling used by groups	RATs, loaders, offensive tools
Mitigation	A defensive control that blocks the technique	M1043 Credential Access Protection
Data source	The telemetry needed to detect the technique	Process creation, command line, authentication logs

How a SOC uses it day to day

- Tagging detections: the SIEM rule that watches for encoded PowerShell is labelled T1059.001.
- Scoring alerts: technique + tactic decide severity, so triage order is consistent between shifts.
- Coverage mapping: a spreadsheet or tool records which techniques have a working rule, which have only logs, and which are blind spots.
- Incident write-ups: the report narrates the attack as a chain of techniques, which shows management exactly which controls failed and where.
- Intel-driven hunting: a new report says an actor is using a specific technique, so the SOC hunts for that technique first, that week.

Key points to remember

- ATT&CK is a catalogue of behaviour, not a catalogue of malware.
- It is free, vendor-neutral and updated continuously - no licence and no cost to use it.
- It is not a checklist that guarantees detection; it is a map that shows where the SOC can see and where it is blind.
- Its greatest strength is that it turns isolated alerts into a story about an adversary's progress.